

TAXFLOW PLATFORM

Technical Build Report
Start Filing Now | Connect Portfolio

Document Type	Technical Architecture & Integration Guide
Sections Covered	Start Filing Now / Connect Portfolio
Audience	Product Managers, Full-stack Engineers, Security Teams
Regulatory Scope	Income Tax Act 1961, SEBI Regulations, RBI Guidelines, IT Act 2000
Prepared For	TaxFlow Platform — AY 2025-26
Version	v1.0 — May 2025

SECTION A

START FILING NOW

This section covers the complete engineering blueprint for the ITR filing wizard — from frontend UI flows and backend APIs to data integrations with government portals, and the security architecture required to protect taxpayer data.

A.1 Overview & User Flow

The 'Start Filing Now' feature is a guided, multi-step ITR wizard that takes a user from zero to a verified, submitted return in under 15 minutes. The flow has 6 discrete steps:

Step	Name	What Happens
Step 1	Identity & PAN Verification	Collect PAN, DOB, AY selection; verify PAN format with NSDL lookup.
Step 2	ITR Form AI Selector	3-question logic tree selects ITR-1 / 2 / 3 / 4 based on income profile.
Step 3	Income Entry	Salary (Form 16), Capital Gains, Business Income, Rental, Other Sources.
Step 4	Deductions Claim	80C, 80D, HRA, NPS, Home Loan Interest, 80TTA — with smart limit alerts.
Step 5	Tax Computation	Old vs New regime comparison engine. Auto-selects the regime saving more tax.
Step 6	Review & e-File	XML generation, prefill validation, e-verify via Aadhaar OTP / Net Banking.

A.2 Frontend Architecture

Tech Stack

- Framework:** Next.js 14 (App Router) — for SSR on public pages, CSR on the secure filing wizard. Reduces first-load time and improves SEO for marketing pages.
- UI Library:** Tailwind CSS + shadcn/ui components. Use Radix UI primitives for accessibility (WCAG 2.1 AA compliance mandatory for govt-linked apps).
- State Management:** Zustand for wizard state (5-step form data persisted in memory, never localStorage). React Query for all API calls.
- Form Validation:** Zod schemas on every step + React Hook Form. PAN is validated as `/[A-Z]{5}[0-9]{4}[A-Z]{1}/` client-side before any API call.

- **Offline Drafts:** IndexedDB (not localStorage) for draft saving, encrypted with a session-derived key.

Filing Wizard Component Architecture

```

FilingWizard (root)
├─ WizardProgress (step indicator)
├─ Step1_Identity      - PAN, DOB, AY
├─ Step2_FormSelector - AI form picker
├─ Step3_Income        - all income sources
├─ Step4_Deductions    - section-wise deductions
├─ Step5_TaxEngine      - regime comparison
└─ Step6_ReviewFile    - XML preview + e-verify
  
```

A.3 Backend Architecture

API Design (REST + gRPC internally)

The backend should be a modular monolith (or microservices for scale) built on Node.js/Express or Python FastAPI. Core services:

Service	Responsibility	Technology
auth-service	JWT + Aadhaar OTP auth	Node.js, Redis sessions, rate limiting
pan-service	PAN validation + 26AS fetch	Python FastAPI, NSDL API client
income-service	Income computation engine	Python, NumPy for calculations
tax-engine	Old/New regime calculator	Pure Python, unit-tested to ₹1 accuracy
itr-xml-service	Generate ITR XML/JSON	Java (official schema), or Python xmltodict
portal-service	Submit to IT e-Filing portal	Node.js with Puppeteer fallback
notification-service	SMS/Email/WhatsApp alerts	AWS SES + Twilio + Gupshup API

A.4 Government API Integrations

1. Income Tax e-Filing Portal (incometax.gov.in)

The Income Tax Department provides APIs under the e-Filing 2.0 portal. To access them:

1. **Register as an e-Return Intermediary (ERI):** Apply via the IT portal. ERIs get access to official APIs for pre-filing, XML validation, and submission.

2. **Pre-filled JSON API:** GET <https://eportal.incometax.gov.in/eri/businessService> — fetches pre-filled data including salary (26AS), TDS, advance tax paid.
3. **XML Upload API:** POST the generated ITR XML to the portal. Schema XSD files are published yearly by CBDT for each ITR form. Validate XML against schema before upload.
4. **Aadhaar e-Verify API:** Integrates with UIDAI's OTP service. User enters Aadhaar number → OTP sent → submit OTP to verify the return.

Critical Note — ERI Registration

You cannot directly access the IT portal APIs without registering as an e-Return Intermediary (ERI). ERI registration requires: (1) DPIIT-registered company, (2) CA/CPA on staff, (3) ₹5 lakh security deposit. Alternatively, partner with an existing ERI like Quicko, Taxmann, or ClearTax via their white-label API.

2. TRACES (26AS / AIS / TIS)

TRACES is the TDS reconciliation and analysis portal. Integration flow:

- **Form 26AS:** Fetches TDS deducted by employer, bank, etc. Requires PAN + DigiLocker OAuth or direct TRACES API (available to ERIs).
- **AIS (Annual Information Statement):** More comprehensive than 26AS — includes SFT data, securities transactions, mutual fund purchases. Available via IT portal pre-fill API.
- **DigiLocker Integration:** User authorises DigiLocker via OAuth2. Fetch 26AS PDF/JSON directly from the IS department's DigiLocker issuer. This is the most user-friendly method.

3. NSDL PAN Verification

Use the NSDL/UTI PAN verification API to validate PAN before any processing. Request free API access at tin.tin.nsdl.com. Returns PAN status (valid/invalid/deactivated) and name as per PAN records.

A.5 Tax Engine — The Core Calculation Module

This is the most critical module — errors here result in wrong tax liability for users. Build it as a standalone, independently testable Python library.

Old Regime Slabs (FY 2024-25 / AY 2025-26)

Income Range	Tax Rate	Notes
Up to ₹2,50,000	Nil	Basic exemption limit
₹2,50,001 – ₹5,00,000	5%	87A rebate applies (nil tax if total income ≤ ₹5L)

Income Range	Tax Rate	Notes
₹5,00,001 – ₹10,00,000	20%	—
Above ₹10,00,000	30%	Surcharge applicable on income > ₹50L

New Regime Slabs (FY 2024-25 — Post Budget 2024)

Income Range	Tax Rate	Notes
Up to ₹3,00,000	Nil	Basic exemption
₹3,00,001 – ₹7,00,000	5%	87A rebate (nil tax up to ₹7L)
₹7,00,001 – ₹10,00,000	10%	—
₹10,00,001 – ₹12,00,000	15%	—
₹12,00,001 – ₹15,00,000	20%	—
Above ₹15,00,000	30%	Standard deduction ₹75,000 allowed

Special Rates (both regimes)

- **STCG (Equity / Equity MF):** 20% flat under Section 111A (changed from 15% in Budget 2024, effective 23 Jul 2024). STCG before 23 Jul 2024 taxed at 15%.
- **LTCG (Equity / Equity MF):** 12.5% on gains above ₹1.25 lakh (increased from 10% / ₹1L in Budget 2024).
- **LTCG (Debt MF post Apr 2023):** Taxed at slab rate — no indexation benefit. Treated as Short-term.
- **VDA / Crypto:** 30% flat + 1% TDS (Section 115BBH / 194S). No set-off of losses allowed.
- **Health & Education Cess:** 4% on total income tax + surcharge.

Engineering Note — Tax Engine Testing

Write unit tests for at least 200 test cases including edge cases: income at exact slab boundaries, rebate 87A cutoff, surcharge bands, STCG+LTCG+slab income combinations, and AMT (Alternate Minimum Tax) for partnership firms. Accuracy to ₹1 is expected. Use pytest with parameterized tests. Integrate a fuzzing harness for edge cases.

A.6 ITR XML Generation

The IT department mandates a specific XML schema for each ITR form. These schemas are published as XSD files each assessment year.

- **Schema Source:** Download from incometax.gov.in/iec/foportal/downloads. File naming: ITR1_AY2526_schema.xsd
- **XML Library:** Use Python's lxml for schema-compliant XML generation. Java's JAXB if using Java. Avoid manual string concatenation — use proper XML builders.

- **Validation:** Always run `xmllint --schema ITR1.xsd return.xml` before submission. The portal rejects malformed XMLs with a cryptic error.
- **JSON Upload:** The new e-filing portal (post 2021) also accepts JSON. Use official schema from the portal. JSON is easier to generate and validate than XML.
- **Checksums:** Include SHA-256 hash of the return data in the submission metadata. This creates a tamper-evident audit trail.

A.7 e-Verification Integration

Method 1: Aadhaar OTP (Recommended)

5. **Step 1:** User provides Aadhaar number linked to PAN. Mask and store only last 4 digits.
6. **Step 2:** Call UIDAI API to trigger OTP to Aadhaar-linked mobile number.
7. **Step 3:** User submits OTP. Verify via UIDAI. On success, mark return as e-verified.
8. **Step 4:** Call IT portal's e-verify API with verification token. Receive ITR-V acknowledgment.

Method 2: Net Banking

Redirect user to their bank's Net Banking portal via a NPCI/bank-specific URL. On successful login, bank returns an EVC (Electronic Verification Code) which is submitted to the IT portal to complete verification.

Method 3: Physical ITR-V

For users who cannot e-verify: generate a signed PDF ITR-V and provide it for printing + mailing to CPC Bangalore within 120 days of filing.

A.8 Advance Tax Calculator Module

Build a real-time advance tax calculator that estimates quarterly liability and sends reminders to avoid Section 234B/234C interest:

Quarter Due	Minimum Cumulative %	When to Notify User
Q1 (15 Jun)	≥15% of total tax	Notify in May
Q2 (15 Sep)	≥45% of total tax	Notify in Aug
Q3 (15 Dec)	≥75% of total tax	Notify in Nov
Q4 (15 Mar)	100% of total tax	Notify in Feb

SECTION B

CONNECT PORTFOLIO

This section details how to build the portfolio aggregation feature — the engine that pulls all investment data from brokers, mutual fund registrars, and other asset classes to auto-compute capital gains and pre-fill the ITR.

B.1 Architecture Overview

The Connect Portfolio feature is a financial data aggregation layer sitting between investment platforms and the tax engine. It works via three primary channels:

Channel	Name	Best For
Channel 1	Account Aggregator (AA) Framework	RBI-regulated, consent-based data sharing. Best for bank + MF data.
Channel 2	CAMS / KFintech MF API	SEBI-regulated registrar APIs for all mutual fund data.
Channel 3	Broker P&L Export APIs	Direct broker integrations (Zerodha Kite, Groww, Upstox) for equity trade history.

B.2 SEBI Account Aggregator (AA) Framework

The Account Aggregator framework is the RBI/SEBI-mandated, consent-driven data sharing architecture for India's financial ecosystem. It is the most compliant and scalable path for portfolio aggregation.

How It Works

- Registration:** Register as a Financial Information User (FIU) with SAHAMATI (the AA ecosystem body). Pay the membership fee (~₹1-5L/year).
- Consent Request:** Your app (FIU) sends a consent request to the AA (e.g., Finvu, OneMoney, Anumati) specifying: data type, purpose, date range, and frequency.
- User Consent:** User approves the consent via their AA app or bank's AA interface. This is fully consent-based — you cannot pull data without user approval.
- Data Fetch:** On approval, AA fetches data from FIPs (Financial Information Providers — banks, brokers, MF registrars) and delivers encrypted to your FIU.
- Decryption:** Your FIU decrypts the data using ECDH key exchange. Data is in standardised FI (Financial Information) schema format.

AA Framework Data Types Available

Bank account statements, Fixed deposits, Equity holdings (via NSDL), Mutual Fund holdings (via CAMS/KFintech), Insurance policies, National Pension System (NPS) details. The AA framework covers most asset classes needed for comprehensive ITR pre-filling.

AA Tech Integration Stack

- **SDK:** Use the official AA Client SDK from SAHAMATI GitHub (sahamati/aa-sdk). Available in Java and Python.
- **AA Partners:** Finvu (finvu.in), OneMoney (onemoney.in), Anumati, Perfios AA. Integrate with 2-3 for redundancy.
- **Consent Artefact Storage:** Store all consent artefacts with timestamps in your database for audit. Consent revocations must be processed within 24 hours.
- **Data Retention:** Under AA regulations, you may only store FI data for the purpose and duration specified in the consent. After the consent expires, delete the raw data — keep only computed outputs (e.g., capital gains figures).

B.3 CAMS & KFintech Mutual Fund APIs

CAMS and KFintech are the two SEBI-registered Registrar and Transfer Agents (RTAs) covering ~99% of all mutual fund AUMs in India. They provide APIs for fetching complete MF transaction history.

CAMS myCAMS API

- **Access:** Register at mycams.com/api. Requires AMFI-registered entity or a tie-up with an AMFI-registered distributor.
- **Authentication:** PAN-based OTP authentication. User enters PAN → CAMS sends OTP to registered mobile → OTP verified → full transaction history returned.
- **Data Returned:** Complete transaction history including NAV on purchase/redemption date, units, folio numbers, cost of acquisition. Essential for FIFO-based LTCG/STCG computation.
- **Format:** JSON and CSV. Parse into normalized transaction objects.

KFintech API

Mirror integration to CAMS. Some fund houses (SBI MF, Sundaram, etc.) are registered with KFintech. Always fetch from both CAMS + KFintech to get complete portfolio.

FIFO Capital Gains Engine for Mutual Funds

Indian tax law mandates FIFO (First In, First Out) method for computing capital gains on MF redemptions. Your engine must:

14. **Sort all purchase transactions** by date (oldest first) for each folio.
15. **For each redemption**, match units redeemed against the oldest available purchase lots.

16. **Compute holding period** for each matched lot to determine STCG vs LTCG classification.
17. **Apply correct tax rate** based on fund type: equity MF (12.5% LTCG >12M), debt MF (slab rate).
18. **Handle STT credits**, switch transactions (treated as redemption + fresh purchase at same NAV), and dividend reinvestments correctly.

B.4 Broker Equity Integrations

Zerodha Kite Connect API

- **Access:** publisher.zerodha.com — Zerodha's publisher platform allows third-party apps to request read-only access to user portfolios.
- **Scopes needed:** orders:read, holdings:read, portfolio:read. Do NOT request trading or order placement scopes.
- **P&L Data:** The tradebook endpoint returns all historical equity trades. Process using FIFO to compute capital gains.
- **Auth:** OAuth2 flow with Kite Connect. Access tokens valid for 1 day — refresh daily or use long-lived publisher tokens.

Groww API

Groww does not have a public API as of 2025. Integration options: (1) Groww's official data export (XLSX) — user downloads and uploads to your platform; parse using xlsx library. (2) CAMS/KFintech covers Groww MF transactions. (3) Wait for Groww AA FIP to go live.

Upstox API

- **Access:** developer.upstox.com — Full OAuth2 API with portfolio and historical data endpoints.
- **Trade Book:** GET /v2/charges/historical-trades returns all trades for a financial year. Use to compute STCG/LTCG.
- **Demat Holdings:** GET /v2/portfolio/long-term-holdings for unsold equity positions.

Other Brokers — CDSL/NSDL Holdings via DEMAT

For brokers without APIs, use the CDSL/NSDL Consolidated Account Statement (CAS):

- **CDSL myeasi:** User can download CAS from myeasi.cdsl.com. Provide a parser for this PDF/email format.
- **NSDL CAS:** Similarly, nsdlcas.com provides combined demat statement. Parse to extract holdings.
- **Email Parsing:** Offer 'Forward your CAS email to taxflow@yourcompany.com' — parse the attached statement automatically. Secure this with S/MIME signed emails.

B.5 Real Estate Module

Rental Income — Schedule HP

- **Data Input:** User enters: annual rent received, municipal tax paid, and home loan interest (for Section 24 deduction). Platform computes NAV (Net Annual Value) and 30% standard deduction automatically.
- **Multiple Properties:** Support up to 3 properties (self-occupied / let-out / deemed let-out). Tax treatment differs — let-out properties are taxed at full NAV.
- **TDS on Rent:** If tenant deducted TDS under Section 194-IB (rent > ₹50K/month), pre-fill Form 26AS TDS credit against rental income.

Capital Gains from Property Sale

- **LTCG (held >2 years):** Use CII (Cost Inflation Index) published by CBDT to compute indexed cost of acquisition. Exempt if reinvested under Section 54 (new house) or 54EC (bonds within 6 months).
- **STCG (held ≤2 years):** Taxed at slab rate. Full gains are taxable without indexation.
- **Stamp Duty Value:** If sale price < stamp duty value (circle rate), Section 50C deems stamp duty value as the sale consideration for tax purposes.

B.6 Fixed Income & Other Assets

Asset Type	Tax Treatment	ITR Integration
FD Interest	TDS under 194A (10% if PAN given)	Fetch from 26AS. Add to Schedule OS under 'Interest from Deposits'
Savings Interest	Exempt up to ₹10K under 80TTA	Auto-apply 80TTA deduction. Excess taxable under Schedule OS.
PPF/EPF	Fully exempt under EEE status	No ITR entry needed for interest. EPF withdrawal taxable if <5yr service.
NPS Withdrawal	Partial exemption	60% lump sum exempt; 40% mandatorily annuity (exempt); partial w/d exempt up to 25%.
Bonds (G-Sec)	Interest taxable at slab	Fetch from Demat holdings. LTCG after 12M at 10%.
Crypto / VDA	30% flat + 4% cess	No deduction except cost. No set-off of VDA losses. Schedule VDA mandatory.

SECTION C

SECURITY ARCHITECTURE

Handling PAN, Aadhaar, income, and financial data makes this platform a high-value target. Security is not optional — it is a legal requirement under the Information Technology Act 2000, DPDP Act 2023, and SEBI/RBI regulations.

C.1 Data Classification & Handling

Classification	Data Types	Handling Rules
Ultra-Sensitive	Aadhaar number, OTP tokens, bank credentials	Never store. Use in memory only. Zero logging.
Highly Sensitive	PAN, income figures, tax computation, ITR XML	AES-256 encrypted at rest. Field-level encryption in DB.
Sensitive	Name, DOB, email, phone, portfolio summary	Encrypted at rest. TLS 1.3 in transit. Masked in logs.
Non-Sensitive	UI preferences, session metadata	Standard security. No special handling.

DPDP Act 2023 — Critical Compliance

Under India's Digital Personal Data Protection Act 2023, you must: (1) Obtain explicit consent before processing personal data, (2) Provide Data Principal rights (access, correction, erasure, grievance), (3) Appoint a Data Protection Officer (DPO), (4) Notify the Data Protection Board within 72 hours of any breach, (5) Localise financial data in India (store in AWS Mumbai / Azure India). Non-compliance penalty: up to ₹250 crore per incident.

C.2 Authentication & Authorization

Multi-Factor Authentication

- Primary:** Mobile OTP (SMS via Twilio or Gupshup with Indian DLT registration). Store OTP hash (bcrypt, not plain text) with 10-minute expiry.
- Secondary:** TOTP via Google Authenticator / Authy for returning users. Optional but recommended for users with portfolio data.
- PAN-based Identity:** After initial OTP login, verify PAN via NSDL API. PAN becomes the primary identity anchor — all data is sharded by encrypted PAN hash.

JWT Token Architecture

- **Access Token:** 15-minute expiry. Contains: user_id, pan_hash, session_id. Signed with RS256 (asymmetric key).
- **Refresh Token:** 7-day expiry. Stored as HttpOnly, Secure, SameSite=Strict cookie. Rotated on every use (refresh token rotation).
- **Session Binding:** Bind tokens to device fingerprint (user-agent + IP range). Flag anomalies.
- **Token Revocation:** Maintain a Redis-based revocation list for immediate logout across all devices.

Role-Based Access Control (RBAC)

Role	Permissions
taxpayer	Own data only. Can read/write own return, portfolio, deductions.
ca_assistant	View-only on assigned client returns. Cannot modify or submit.
ca_authorised	Full access on client returns. Can submit after client e-verification.
platform_admin	Infra management only. Zero access to taxpayer financial data.
auditor	Read-only access to anonymised aggregate data for compliance reporting.

C.3 Encryption Standards

At Rest

- **Database:** PostgreSQL with Transparent Data Encryption (TDE) enabled. Use AWS RDS with encryption-at-rest via KMS.
- **Field-Level Encryption:** PAN, Aadhaar reference, income figures encrypted with AES-256-GCM at application level before DB storage. Key stored in AWS KMS / HashiCorp Vault.
- **File Storage:** ITR XMLs, Form 16 PDFs stored in AWS S3 with server-side encryption (SSE-KMS). Pre-signed URLs with 5-minute expiry for user downloads.
- **Backups:** Encrypted with separate KMS key. Cross-region backup for disaster recovery. Test restores quarterly.

In Transit

- **TLS 1.3 minimum:** Enforce via HSTS header with max-age 2 years. Disable TLS 1.0/1.1 completely.
- **Certificate Pinning:** Pin certificates in mobile apps to prevent MITM via rogue CAs.
- **API Gateway:** Use AWS API Gateway or Kong with mutual TLS for service-to-service communication. No plaintext internal calls.

C.4 Application Security

Input Validation & Injection Prevention

- **PAN Validation:** Regex + NSDL API check on every entry. Reject invalid PANs before any processing.
- **SQL Injection:** Use parameterized queries only. Never string-concatenate SQL. Use an ORM (Prisma, SQLAlchemy) with parameterization enforced.
- **XSS Prevention:** Content Security Policy (CSP) header. DOMPurify for any user-generated content rendering. React's default JSX escaping handles most cases.
- **CSRF Protection:** SameSite=Strict cookies. Double-submit cookie pattern for state-changing requests.

Rate Limiting Strategy

Endpoint	Limit	Action on Breach
OTP Request	3 per mobile number per hour	429 + 1hr lockout on breach
PAN Verification	5 per user per day	Flag for manual review on breach
ITR Submission	3 per user per AY	Block + admin alert on breach
API Global	1000 req/min per IP	CloudFlare rate limiter
Login Attempts	5 failures → 30min lockout	Progressive backoff

Audit Logging

Every sensitive action must be immutably logged with timestamp, user_id, IP, action type, and before/after values. Use append-only storage (AWS CloudWatch Logs or Loki with write-once policy):

- **Log ALL:** Login/logout, PAN lookups, ITR submissions, portfolio link/unlink, data exports, admin access.
- **Never Log:** OTP values, full Aadhaar numbers, bank account numbers, passwords.
- **Retention:** Minimum 7 years (matches IT Act assessment period). Encrypt logs at rest.
- **Alerting:** Real-time alerts for: 5+ failed logins, off-hours admin access, bulk data exports, ITR submission from new device.

C.5 Infrastructure Security

Cloud Architecture (AWS India Region — ap-south-1)

- **VPC Isolation:** All database and internal services in private subnets. Only API Gateway in public subnet behind CloudFront + WAF.
- **AWS WAF:** Configure rules for: SQLi, XSS, IP reputation, geo-restriction (India-only for financial data APIs). Enable OWASP Top 10 managed ruleset.
- **KMS Key Rotation:** Automatic key rotation every 365 days. Separate keys for DB encryption, S3, and application secrets.

- **Secrets Management:** AWS Secrets Manager or HashiCorp Vault for all API keys (NSDL, Zerodha, CAMS etc.). Zero hardcoded credentials anywhere in code.
- **Container Security:** Run services in Docker on ECS Fargate (serverless containers). No direct EC2 SSH access. Use AWS Systems Manager Session Manager for debugging.

Security Scanning & DevSecOps

- **SAST:** Run Semgrep or SonarQube on every commit. Block PRs with high/critical findings.
- **Dependency Scanning:** npm audit and pip-audit in CI pipeline. Auto-update deps with Dependabot. Pin transitive dependencies.
- **DAST:** Run OWASP ZAP scans on staging before every major release.
- **Penetration Testing:** Annual pentest by a CERT-In empanelled security auditor (mandatory if you register as ERI). Bug bounty program after launch.

C.6 Third-Party Risk Management

Every broker, AA, or government API integration is a potential supply-chain risk. Manage these:

- **Vendor Assessment:** Before integrating any API, verify: ISO 27001 / SOC 2 certification, breach history, data processing agreement (DPA) in place, SEBI/RBI registration status.
- **Minimal Scopes:** Request only read-only scopes from broker APIs. Never request trading or withdrawal permissions.
- **Data Minimization:** Do not store raw brokerage data beyond what is needed for tax computation. Delete source trade data after STCG/LTCG figures are computed and user ITR is filed.
- **API Key Rotation:** Rotate all third-party API keys every 90 days. Revoke compromised keys within 15 minutes (automate with Vault).

C.7 Incident Response Plan

Priority	Examples	Response SLA
P0 — Critical	PAN/income data breach, Aadhaar data exposure, unauthorized ITR filing	< 1 hour: Isolate, patch, notify CERT-In + DPDPB within 72h
P1 — High	Auth bypass, large-scale OTP abuse, API credential leak	< 4 hours: Revoke credentials, force password reset, notify users
P2 — Medium	Rate limit bypass, minor data exposure (non-financial)	< 24 hours: Patch, log review, no mandatory notification
P3 — Low	UI bugs, non-sensitive config exposure	< 72 hours: Standard patch cycle

SECTION D — MAINTENANCE & OPERATIONS

D.1 Annual Tax Update Cycle

The ITR platform must be updated EVERY year. Budget changes, slab revisions, and schema updates happen every February–April. Build a maintenance calendar:

Date	Event	Action Required
February 1	Union Budget presented	Begin impact analysis. Identify slab/rate changes.
February – March	CBDT Finance Act notification	Update tax engine slabs, rates, deduction limits in code.
March – April	New ITR schemas published	Download new XSD/JSON schemas. Update XML generator.
April 15	AY opens for filing	QA test all computation paths. Run 200 test cases.
April 30	Launch new AY support	Deploy, monitor for computation errors in first week.
July 31	Filing deadline	Scale up infra for peak traffic. War room staffed.

D.2 Performance & Scaling

- **Filing Season Traffic:** Expect 80% of annual traffic in June-July. Use auto-scaling groups. Pre-warm for 10x normal load by June 15.
- **Tax Engine Caching:** Cache computation results for identical input sets with short TTL. Reduces load significantly on peak days.
- **Database:** PostgreSQL with read replicas for the wizard (reads outnumber writes 10:1). Use connection pooling (PgBouncer). Archive returns older than 3 years to cold storage.
- **Government API Limits:** TRACES and IT portal APIs have rate limits. Implement exponential backoff + queue (SQS) for bulk 26AS fetches.

D.3 Compliance Monitoring

- **CBDT Circulars:** Subscribe to incometax.gov.in RSS and IT department email list. Assign a compliance officer to review weekly.
- **Schema Versions:** Monitor IT portal for schema updates mid-year (corrections happen). Auto-test XML against current schema daily via CI.
- **ERI Compliance:** ERIs must submit quarterly compliance reports. Maintain audit logs as evidence of secure operations.

- **DPDP Compliance:** Annual data protection audit. Consent records review. Data deletion verification for expired consents.

D.4 Recommended Tech Stack Summary

Layer	Technology	Notes
Frontend	Next.js 14, Tailwind CSS, Zustand, React Hook Form + Zod	SSR for marketing, CSR for filing wizard
Backend API	Python FastAPI + Node.js (BFF)	FastAPI for tax engine, Node.js for API gateway
Tax Engine	Python 3.11, pytest, pandas	Isolated library, 200+ unit tests, annual update
Database	PostgreSQL 16 (AWS RDS), Redis 7	Encrypted RDS, Redis for sessions/cache
File Storage	AWS S3 (SSE-KMS)	ITR XML, Form 16, CAS statements
Auth	Custom JWT (RS256) + UIDAI OTP	No OAuth social login for financial data
Secrets	AWS KMS + Secrets Manager	Zero hardcoded secrets
Monitoring	CloudWatch + Grafana + Sentry	Error tracking + infra metrics
CI/CD	GitHub Actions + Semgrep + OWASP ZAP	Security gates in pipeline
CDN/WAF	CloudFront + AWS WAF (OWASP rules)	India edge nodes, geo-restriction

END OF REPORT

This document should be reviewed with a CA, legal counsel, and security auditor before development begins.